



Web Application Security

Part 4

Updated July 28, 2026

Presented at SNU Chennai

Sivasubramanian Natarajan

Recommended Text books

- Web Application Security, Andrew Hoffman (O'Reilly)
- Grokking Web application security, Malcom Macdonald (Manning Books)

Recap

Previous class Summary

- Cookies deep dive
- Browser Window Management
- Contextualizing Topics, Rigorous definitions, Operationalizing and Capturing data for an intended outcome / Task identification or input to another topic.
- Operationalization is achieved through Frameworks / Formula / Process

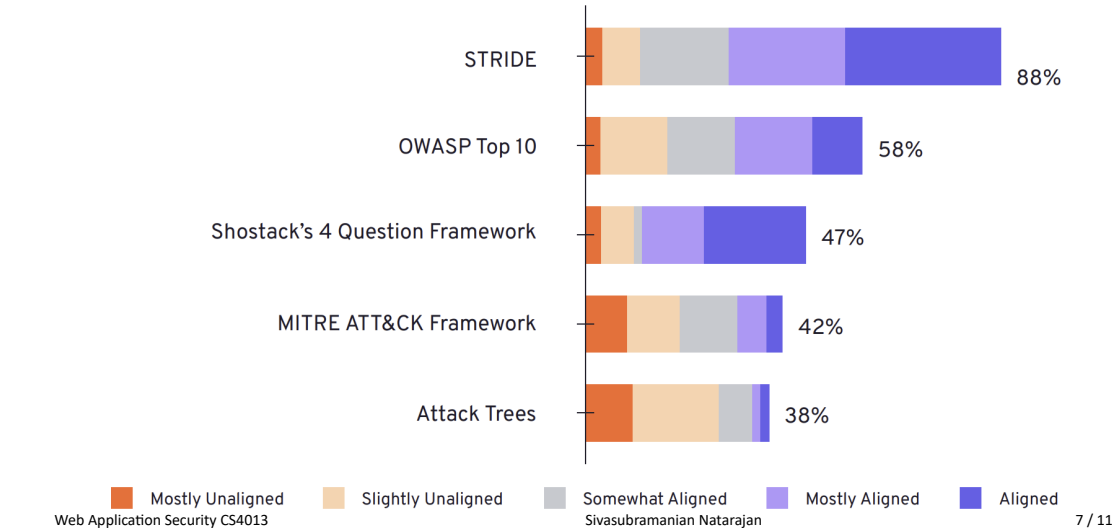
Contextualization

- Policy / Governance
- Design / Implementation
- Cyber Resilience
- Assessments / Assurance

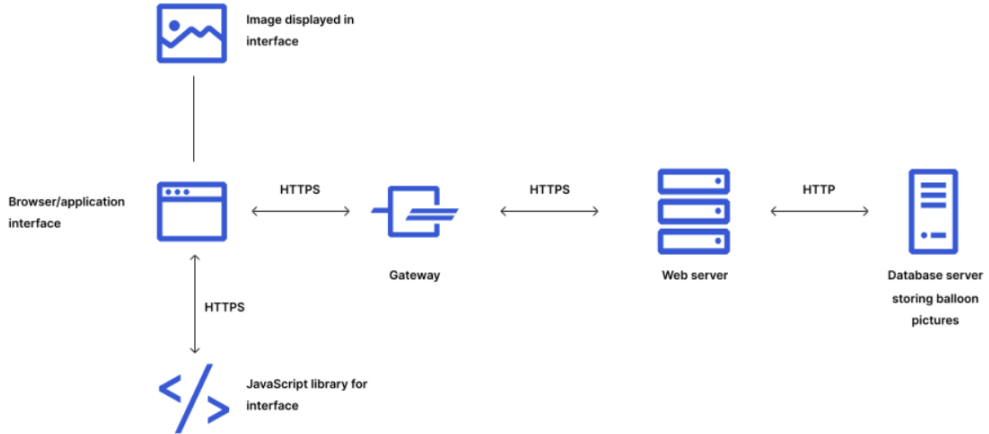
A threat model and structure of Web application

Refer and download State of Threat model report

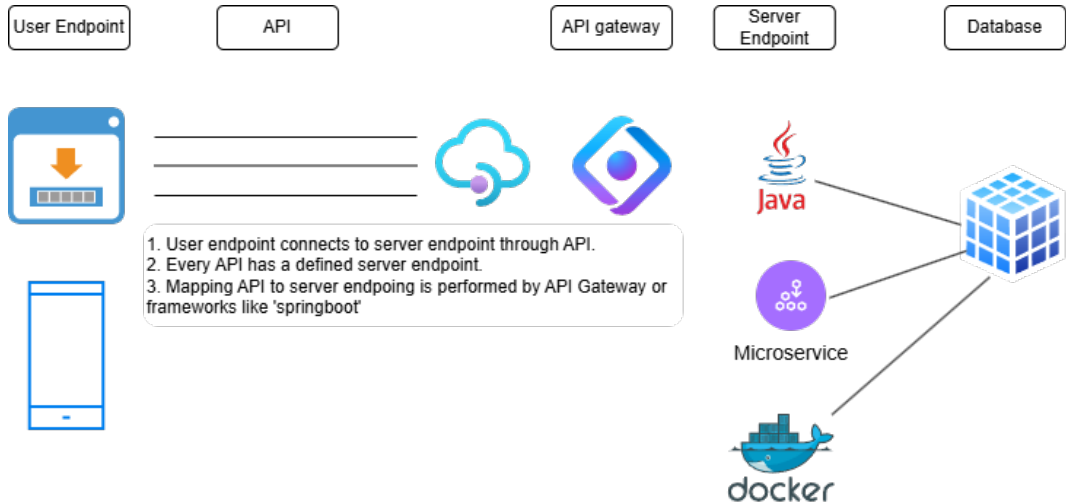
<https://www.threatmodelingconnect.com/state-of-threat-modeling-2024-25>



A simple structure of Web application



API Illustration



Server Side Threats elaboration

Brainstorming / Class discussion

- User Identity
- User Authorization and Entitlements
- API Identity
- Need for User cookies and API token
- Denial of Service
- Cross site Scripting
- Cross site request Forgery
- SQL Injection

Every known threat has a well documented countermeasures to be implemented during the development of the web application itself.

Identity and Access management Introduction

